

Authenticated Stored XSS allowing attacker inject malicious script

Author: Spycio.Kon

Date: 04/03/2026

Enviroment: test on Maxsite 109.3

Link: <https://github.com/maxsite/cms/tree/master>

Description: The vulnerable exist in the plugin ushki. The f_ushka_new, f_ushk are not sanitize allow attacker inject malicious script

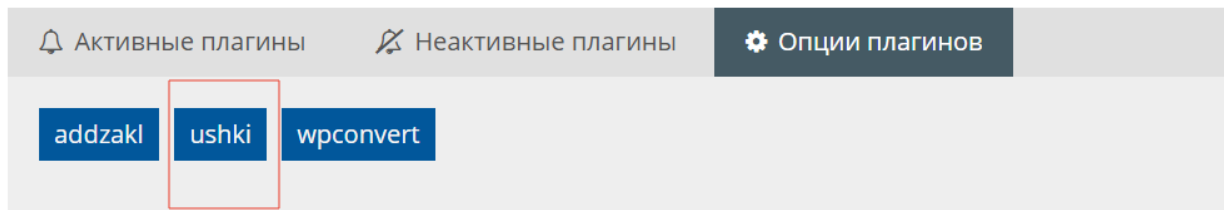
Impact: Because the payload is stored, this attack does not require repeated interaction from the attacker and can.

affect multiple users, leading to account compromise, data manipulation, or full takeover of the administrative Panel by using other endpoint

Reproduce

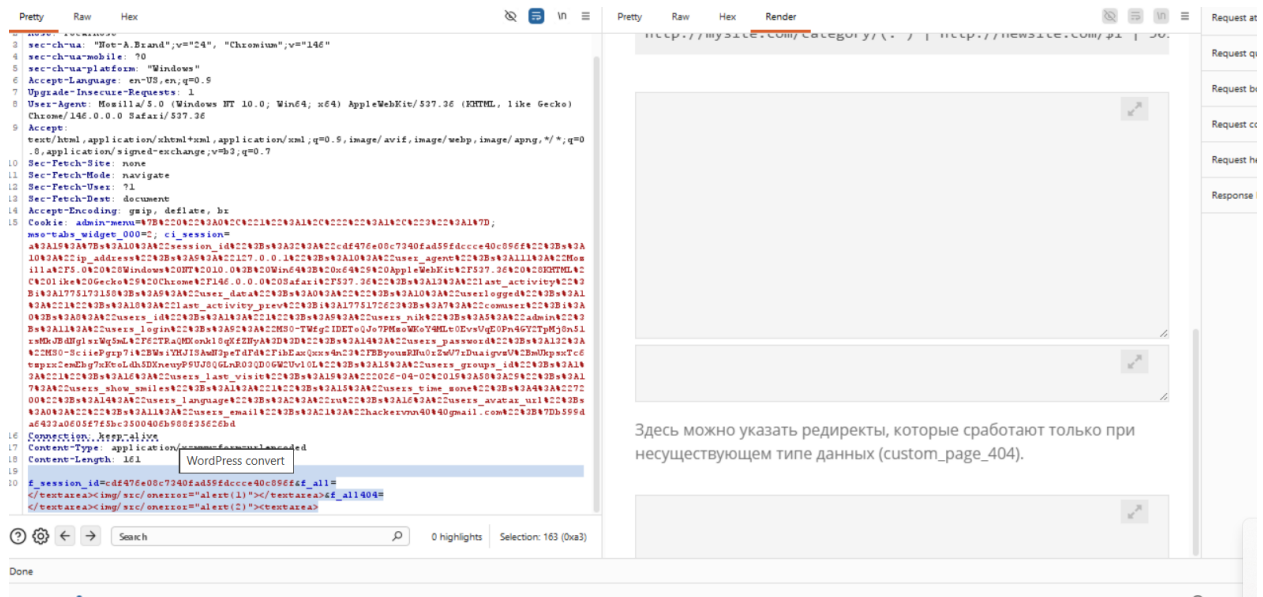
Step1: Enable ushki

настройки, что позволяет избежать «замусоривания» базы данных.

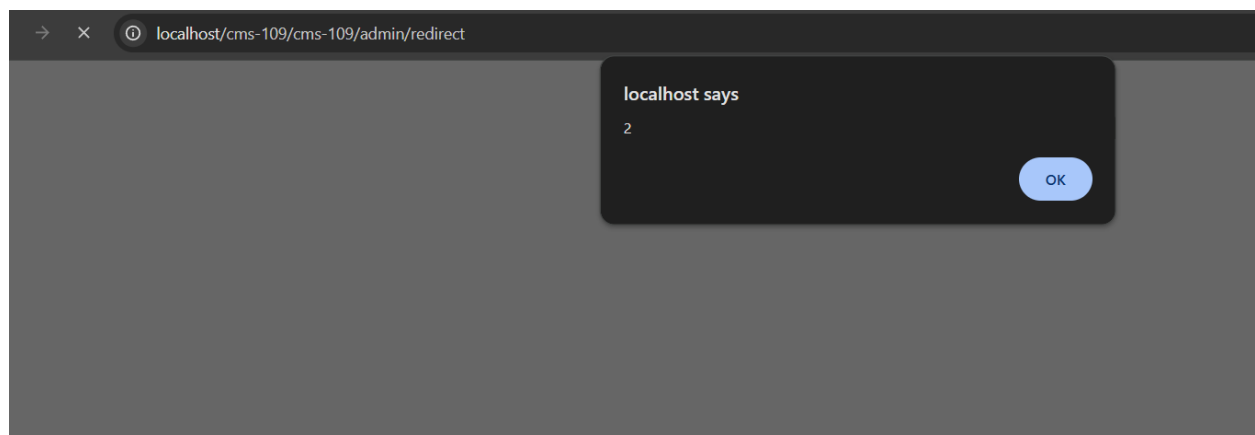


Step2: Send the POST request with f_ushka_new, f_ushk parameter belike.

f_session_id=cdf476e08c7340fad59fdccce40c896f&f_ushka_new=%22%3E%3Cimg%2Fsrc%2Fonerror%3D%22alert%281%29%22%3E&f_submit_new=



Step3: Go to http://localhost/cms-109/cms-109/admin/plugin_ushki again



The root cause:

```
37 // новая ушка
38 <?php
39 if ( $post = mso_check_post(array('f_session_id', 'f_submit_new', 'f_ushka_new')) )
40 {
41     mso_checkreferer();
42     if ($ushka_new = trim($post['f_ushka_new']))
43     {
44         // текущие ушки
45         $ushki = mso_get_float_option('ushki', 'ushki', array());
46         $ushki[] = array('name' => $ushka_new, 'type' => 'html', 'text' => '' ); // добавили новую
47         mso_add_float_option('ushki', $ushki, 'ushki'); // и в опции
48         echo '<div class="update pos-fixed w200px pad10 pos20-r pos0-t t-center"> . t('Ушка добавлена!') . '</div>';
49     }
50     else
51     {
52         echo '<div class="error pos-fixed w200px pad10 pos20-r pos0-t t-center"> . t('Необходимо указать название ушки!') . '</div>';
53     }
54 }
55
56 if ( $post = mso_check_post(array('f_session_id', 'f_submit', 'f_ushka')) )
57 {
58     mso_checkreferer();
59     $ushki = $post['f_ushka'];
60     $ushki_new = array();
61     foreach ($ushki as $us)
62     {
63         if (!isset($us['delete'])) $ushki_new[] = $us;
64     }
65     mso_add_float_option('ushki', $ushki_new, 'ushki');
66     echo '<div class="update pos-fixed w200px pad10 pos20-r pos0-t t-center"> . t('Обновлено!') . '</div>';
67 }
68
69 * $ushki = mso_get_float_option('ushki', 'ushki', array());
70 usort($ushki, "ushki_cmp");
71
72 /*
73 [0] =>
```

The diagram illustrates the flow of data from the 'f_ushka' post variable to the 'ushki' array and then to the 'ushki' option. Red arrows indicate the following sequence:

- From line 59, `$ushki = $post['f_ushka'];`, an arrow points to line 60, `$ushki_new = array();`.
- From line 60, an arrow points to line 61, `foreach ($ushki as $us)`.
- From line 61, an arrow points to line 62, `if (!isset($us['delete'])) $ushki_new[] = $us;`.
- From line 62, an arrow points to line 63, `mso_add_float_option('ushki', $ushki_new, 'ushki');`.
- From line 63, an arrow points to line 64, `echo '<div class="update pos-fixed w200px pad10 pos20-r pos0-t t-center"> . t('Обновлено!') . '</div>';`.
- From line 64, an arrow points to line 65, `$ushki = mso_get_float_option('ushki', 'ushki', array());`.
- From line 65, an arrow points to line 66, `usort($ushki, "ushki_cmp");`.

A handwritten '2' is next to line 65.

```

94     echo '<form method="post">' . mso_form_session('f_session_id')
95     . '<div class="mar20-tb t-1h100"><input name="f_ushka_new" type="text" value="" placeholder="" . t('Новая ушка...') . ""> <button type="submit" name="f_submit_new" c
96
97     $form = '';
98
99     $alpha = $class_alpha = $beta = '';
100     $classA = 'mar20-t';
101
102     foreach ($ushki as $id => $us)
103     {
104         $sel_html = $sel_php = '';
105
106         if ($us['type'] == 'php')
107             $sel_php = ' selected="selected" ';
108         else
109             $sel_html = ' selected="selected" ';
110
111         $ra = explode("\n", htmlspecialchars($us['text']));
112         $rr = count($ra);
113
114         // если в строке больше 80 символов, добавляем row
115         foreach($ra as $rs)
116         {
117             $l = mb_strlen($rs, 'UTF8');
118             if ($l > 80) $rr = $rr + floor($l / 80);
119         }
120
121         if ($rr > 20) $rr = 20;
122         if ($rr < 2) $rr = 2;
123
124         $alpha = mb_substr($us['name'], 0, 1);
125         if ($alpha != $beta) $class_alpha = $classA;
126
127         $form .=
128         '<div class="ushka show ' . $class_alpha . '"><dl>
129         <dt class="show-header"><a href="#" class="link"><span class=""> . $us['name'] . '</span></a></dt>'
130         . '<dd class="show-text">'
131         . '<p class="ushki_title">
132         <input name="f_ushka[' . $id . '][name]" type="text" class="ushka_name" value="" . $us['name'] . "">
133         <select name="f_ushka[' . $id . '][type]">
134             <option value="html" . $sel_html . ">TEXT/HTML</option>
135             <option value="php" . $sel_php . ">PHP</option>
136         </select>
137         <label class="mar20-r"><input class="mar10-l" name="f_ushka[' . $id . '][delete]" type="checkbox"> . t('Удалить') . '</label>
138         <button type="button" class="button t90 pad5-tb pad10-r1" title="" . t('Абзац') . "" onClick="UaddText('\<p>\', '\</p>\', ' . $id . ') ">P</button>
139         <button type="button" class="button t90 pad5-tb pad10-r1" title="" . t('Жирный') . "" onClick="UaddText('\<b>\', '\</b>\', ' . $id . ') ">B</button>
140         <button type="button" class="button t90 pad5-tb pad10-r1" title="" . t('Курсив') . "" onClick="UaddText('\<i>\', '\</i>\', ' . $id . ') ">I</button>
141         <button type="button" class="button t90 pad5-tb pad10-r1" title="" . t('Ссылка') . "" onClick="UaddText('\<a href=&quot;&quot;\', '\</a>\', ' . $id . ') ">A</button>
142         <button type="button" class="button t90 pad5-tb pad10-r1" title="" . t('Блок DIV') . "" onClick="UaddText('\<div>\', '\</div>\', ' . $id . ') ">D</button>
143         <button type="button" class="button t90 pad5-tb pad10-r1" title="" . t('Элемент SPAN') . "" onClick="UaddText('\<span>\', '\</span>\', ' . $id . ') ">S</button>
144         <button type="button" class="button t90 pad5-tb pad10-r1" title="" . t('Заголовок H1') . "" onClick="UaddText('\<h1>\', '\</h1>\', ' . $id . ') ">H</button>
145         </p>
146         <textarea id="ut" . $id . "" name="f_ushka[' . $id . '][text]" rows="" . $rr . ""> . htmlspecialchars($us['text']) . '</textarea>
147         </dd>
148         </dl></div>';

```